

Strict Scope Boundaries & Sourcing Isolation: Functional and non-functional specifications are derived exclusively from documented baseline requirements. Proposed future extensions (Nutrition tracking, BMI calculation, Wearable device integration, Workout reminders, and Fitness analytics dashboards) are strictly excluded from baseline release.

1. FUNCTIONAL REQUIREMENTS SPECIFICATIONS

Defines mandatory functional capabilities implemented across controllers, models, and middleware layers for the single Authenticated User role.

FR-01: Cryptographic Authentication & Identity Provisioning The system must manage user onboarding and secure identity validation using bcrypt.js and JSON Web Tokens (JWT). FR-01.1: Support registration (POST /api/auth/register) requiring name, email, and password. Reject duplicate emails with HTTP 400 Bad Request. FR-01.2: Passwords must be hashed using bcrypt.js before database persistence. Plain text storage is strictly forbidden. FR-01.3: Support login (POST /api/auth/login) validating email and hashed password. Returns signed JWT and user metadata on HTTP 200 OK. FR-01.4: Implement Auth Guard middleware to inspect Authorization: Bearer <token>, verify token with JWT_SECRET, and reject unauthenticated requests with HTTP 401 Unauthorized. FR-01.5: Support profile retrieval (GET /api/auth/profile) returning user info while omitting the hashed password field.	AUTHENTICATION
FR-02: Workout Lifecycle & CRUD Operations The system must manage workout logging, multi-format retrieval, modifications, and deletions strictly tied to the logged-in user. FR-02.1: Persist workouts (POST /api/workouts) validating name, category, duration, caloriesBurned, and date, injecting userId from token context. FR-02.2: Retrieve workouts (GET /api/workouts) filtering strictly by authenticated user's userId. FR-02.3: Query single record (GET /api/workouts/:id) enforcing cross-user tenant isolation; unauthorized traversals return HTTP 404 Not Found. FR-02.4: Update workouts (PUT /api/workouts/:id) and delete workouts (DELETE /api/workouts/:id) enforcing user ownership checks.	WORKOUT MANAGEMENT
FR-03: Multi-Criteria Query Filtering The workout retrieval engine must support granular query filtering based on documented criteria. FR-03.1: Support simultaneous or independent filtering across query parameters: name, category, and date on GET /api/workouts. FR-03.2: Dynamic queries must maintain user-scope constraints so that filtered results never leak records across different accounts.	SEARCH ENGINE
FR-04: Generative AI Workout Regimen Recommendation The system must provide personalized generative exercise regimens using the Google Gemini API. FR-04.1: Process POST /api/ai/recommend requiring authenticated session and body parameters: goal and fitnessLevel. FR-04.2: Construct structured prompt contextualizing user inputs and dispatch HTTPS request to Google Gemini API via GEMINI_API_KEY.	AI INTELLIGENCE

2. FUNCTIONAL REQUIREMENTS (CONT.)

FR-05: AI Historical Fitness Insights & Analytics

AI INTELLIGENCE

The system must synthesize historical workout activities into intelligent progress feedback using Google Gemini.

- FR-05.1:** Support GET `/api/ai/insights` requiring valid Bearer JWT authentication.
- FR-05.2:** Aggregate authenticated user's historical workout records from MongoDB and formulate structured analytical prompt context.
- FR-05.3:** Return Google Gemini generative analysis detailing exercise consistency, performance trends, and recommendations.

FR-06: Centralized Exception Handling & Standardized Responses

MIDDLEWARE

The system must handle all runtime, database, and third-party exceptions through a single centralized error middleware.

- FR-06.1:** Intercept Mongoose schema validation failures and duplicate key violations, formatting them into clear HTTP 400 responses.
- FR-06.2:** Catch external Google Gemini API connection faults, returning structured HTTP 500 error responses without leaking internal stack traces.

3. NON-FUNCTIONAL REQUIREMENTS SPECIFICATIONS

Defines structural criteria, security invariants, performance baselines, and reliability standards for FitTrack AI.

NFR ID	QUALITY ATTRIBUTE	SPECIFICATION & ARCHITECTURAL STANDARD	VALIDATION CRITERIA
NFR-01	Cryptographic Security & Isolation	Passwords hashed with bcrypt.js prior to persistence; stateless authentication enforced via cryptographically signed JSON Web Tokens. Cross-tenant access prevented via query user binding.	No plain text passwords in MongoDB; JWT signature verification required on all protected routes.
NFR-02	Data Integrity & Strict Typing	Mongoose schemas must enforce strict type casting, field requirements, and relational consistency between User and Workout collections (user Id ObjectId reference).	Mongoose schema rejects missing required fields and invalid data types with HTTP 400.
NFR-03	API Gateway Reliability	Node.js Express application must utilize CORS middleware for cross-origin security, dotenv for environmental isolation, and express.json() parser for payload hygiene.	Standardized JSON response headers; environment variables isolated from code repository.
NFR-04	Third-Party Resiliency	Google Gemini API interactions must execute within isolated asynchronous try-catch blocks to prevent downstream external latency from halting the Express server process.	AI service timeouts or faults trigger graceful HTTP 500 JSON error responses without crashing gateway.
NFR-05	Maintainability & Modularity	Codebase must maintain strict Model-View-Controller (MVC) architectural separation: <code>/controllers</code> , <code>/models</code> , <code>/routes</code> , <code>/middleware</code> , and <code>/config</code> .	100% adherence to documented MVC directory structure and single responsibility principle.

4. EXHAUSTIVE REQUIREMENT TRACEABILITY MATRIX (RTM)

Maps functional requirements across controllers, database models, route endpoints, and security mechanisms.

REQ ID	TARGET ROUTE ENDPOINT	CONTROLLER IMPLEMENTATION	DATA MODEL	SECURITY / GUARD	USER STORY REF
FR-01	POST /api/auth/register	authController.register	User Model (name, email, password)	bcrypt.js hashing JWT verification Auth Middleware	US-01 US-02
	POST /api/auth/login	authController.login			
	GET /api/auth/profile	authController.getProfile			
FR-02	POST /api/workouts	workoutController.createWorkout	Workout Model (userId, name, category, duration, caloriesBurned, date)	Bearer JWT Guard Tenant Isolation Record Ownership Verification	US-03 US-04 US-05
	GET /api/workouts	workoutController.getWorkouts			
	GET /api/workouts/:id	workoutController.getWorkoutById			
	PUT /api/workouts/:id	workoutController.updateWorkout			
	DELETE /api/workouts/:id	workoutController.deleteWorkout			
FR-03	GET /api/workouts?category=..	workoutController.getWorkouts	Workout Model	Bearer JWT Guard Scoped Filter Object	US-04
FR-04	POST /api/ai/recommend	aiController.getRecommendation	N/A (External API)	Bearer JWT Guard Gemini API Key Env	US-06
FR-05	GET /api/ai/insights	aiController.getInsights	Workout Model	Bearer JWT Guard User ID Aggregation	US-07
FR-06	All Application Endpoints	middleware/errorHandler.js	All Application Models	Sanitized Error DTO Stack Trace Concealment	All Stories

5. SCOPE BOUNDARIES & FUTURE ENHANCEMENT ISOLATION

Strict demarcation isolating in-scope baseline deliverables from out-of-scope future extensions.

DOMAIN FEATURE	LIFECYCLE CLASSIFICATION	ARCHITECTURAL BOUNDARY RATIONALE
User Auth & Profiles	IN-SCOPE BASELINE	Mandatory security foundation for multi-user data isolation and API protection.
Workout CRUD & Search	IN-SCOPE BASELINE	Core domain functionality providing workout logging and multi-criteria querying.
Gemini Recommendations & Insights	IN-SCOPE BASELINE	Core generative intelligence engine providing exercise regimens and workout history insights.
Nutrition Tracking	STRICTLY EXCLUDED	Classified strictly as a future enhancement; excluded from baseline schemas and routes.
BMI Calculation	STRICTLY EXCLUDED	Classified strictly as a future enhancement; excluded from baseline schemas and routes.
Wearable Device Integration	STRICTLY EXCLUDED	Classified strictly as a future enhancement; hardware sync protocols not supported in baseline.
Workout Reminders & Push	STRICTLY EXCLUDED	Classified strictly as a future enhancement; notification brokers not supported in baseline.
Fitness Analytics Dashboards	STRICTLY	Classified strictly as a future enhancement; advanced visualization layers excluded